UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

Ingeniería de Software

Identificación de activos y análisis de riesgos

Aplicación de salas de chat seguras

Asignatura: Desarrollo de Software Seguro

Docente: Angel Cudco

NRC: 36900

Integrantes

Jeancarlo Santi
Josue Solano
Alexander Toapanta

Sangolquí, Ecuador
08 de octubre de 2026

Contenido

1 Introducción y contexto **1**

2 Alcance de la aplicación **1**

3 Conceptos y método de análisis **2**

4 Políticas de seguridad **4**

5 Inventario de activos **5**

6 Evaluación general de riesgos **6**

7 Análisis y tratamiento de los quince riesgos **7**

8 Indicadores de seguridad **12**

9 Conclusiones **12**

Referencias **13**

Índice de tablas

1 Funciones comprendidas en el alcance . . . 1
2 Conceptos utilizados en el análisis . . . 2
3 Escala de probabilidad . . . 2
4 Escala de impacto . . . 3
5 Clasificación del riesgo . . . 3
6 Políticas de seguridad para la aplicación . . . 4
7 Quince activos y su importancia para el proyecto . . . 5
8 Riesgo inherente y residual de los quince escenarios . . . 6
9 Análisis del riesgo R01 . . . 7
10 Análisis del riesgo R02 . . . 7
11 Análisis del riesgo R03 . . . 7
12 Análisis del riesgo R04 . . . 8
13 Análisis del riesgo R05 . . . 8
14 Análisis del riesgo R06 . . . 8
15 Análisis del riesgo R07 . . . 9
16 Análisis del riesgo R08 . . . 9
17 Análisis del riesgo R09 . . . 9
18 Análisis del riesgo R10 . . . 10
19 Análisis del riesgo R11 . . . 10
20 Análisis del riesgo R12 . . . 10
21 Análisis del riesgo R13 . . . 11
22 Análisis del riesgo R14 . . . 11
23 Análisis del riesgo R15 . . . 11
24 Indicadores y metas de seguridad . . . 12

Índice de figuras

1 Relación general entre los componentes del chat . . . 1
2 Matriz de probabilidad e impacto . . . 3

1 Introducción y contexto

Este documento identifica quince activos de una aplicación de salas de chat seguras y analiza un escenario prioritario por activo. El objetivo es convertir los requisitos del proyecto en decisiones de seguridad trazables: qué se protege, qué puede fallar, cómo se valora ese fallo, qué control se aplica y qué evidencia permitirá comprobarlo.

La aplicación permitirá que un administrador cree y gestione salas con una clave de acceso, un número máximo de participantes y un tipo de comunicación: texto, multimedia o ambos. Los usuarios deberán ingresar a la sala correspondiente y conectarse desde un solo dispositivo a la vez. Los mensajes y archivos requieren protección durante su envío, y los archivos deberán revisarse antes de compartirse.

Consideramos especialmente importante proteger los datos de acceso, las conversaciones y el funcionamiento del chat. También se requiere reconocer archivos sospechosos, incluidos aquellos que puedan ocultar información mediante esteganografía, y registrar los eventos relevantes de seguridad.

Para orientar el análisis tomamos como referencia ISO/IEC 27001, relacionada con la gestión de la seguridad de la información, e ISO/IEC 27034-1, enfocada en incorporar seguridad en las aplicaciones [1, 2].

2 Alcance de la aplicación

El análisis abarca el acceso del administrador, la creación y configuración de salas, el ingreso de participantes, el control de sesiones, el envío de mensajes, la transferencia y revisión de archivos, las claves de cifrado, la base de datos y los registros de seguridad. Se consideran los riesgos relacionados con estas funciones y sus posibles consecuencias para los usuarios.

Tabla 1: Funciones comprendidas en el alcance

Componente	**Función**
Administración y acceso	Gestionar salas y comprobar quién puede ingresar o realizar cambios.
Sesiones y mensajes	Evitar conexiones simultáneas no autorizadas e identificar al remitente de cada mensaje.
Archivos multimedia	Revisar el tipo y contenido antes de compartir; retener archivos sospechosos.
Datos y registros	Proteger información almacenada y conservar eventos relevantes de seguridad.

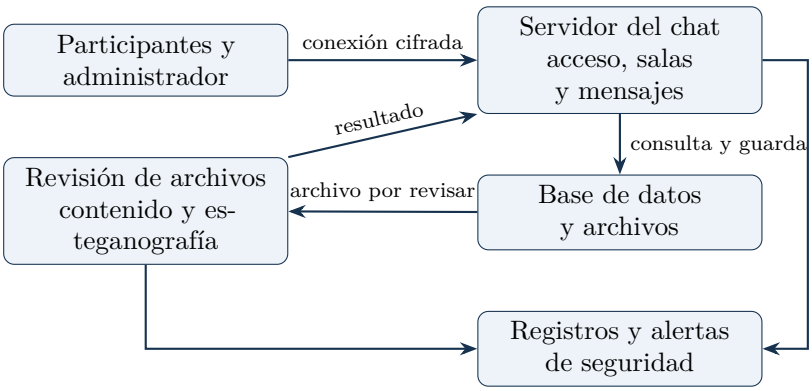


Figura 1: Relación general entre los componentes del chat

La revisión de archivos entrega su resultado al servidor; este decide si el archivo puede compartirse. Para controlar una sola conexión por usuario, el servidor debe reconocer una identidad estable y revisar sus sesiones activas. La clave de la sala permite ingresar, pero por sí sola no distingue a una persona de otra.

3 Conceptos y método de análisis

Tabla 2: Conceptos utilizados en el análisis

Concepto	Significado y ejemplo
Activo	Elemento valioso que necesita protección; por ejemplo, las credenciales del administrador.
Amenaza	Actor o evento que puede causar daño; por ejemplo, un atacante que intenta adivinar una contraseña.
Vulnerabilidad	Debilidad que facilita la amenaza; por ejemplo, una contraseña sencilla y sin límite de intentos.
Riesgo	Posibilidad de que la amenaza aproveche la debilidad y cause una consecuencia; por ejemplo, acceso no autorizado a la administración.
Control	Medida para reducir la probabilidad o el daño; por ejemplo, una segunda verificación de identidad.
Riesgo inherente	Riesgo calculado antes de considerar el tratamiento seleccionado.
Riesgo residual	Riesgo que permanece después del tratamiento. Puede reducirse más con otros controles.

Tríada CID. Confidencialidad: solo acceden personas autorizadas. Integridad: la información conserva su contenido y no se altera indebidamente. Disponibilidad: el servicio puede utilizarse cuando se necesita. En las tablas se indican como C, I y D, respectivamente [1].

3.1 Método seleccionado

Se decidió utilizar una matriz de probabilidad e impacto de cinco niveles, tomando ISO/IEC 27005 como referencia para organizar el análisis [3]. Elegimos este método porque permite comparar los riesgos de forma sencilla y justificar qué situaciones requieren más atención.

La **probabilidad (P)** expresa qué tan fácil y viable sería que ocurra el escenario. El **impacto (I)** expresa la gravedad de su consecuencia. Ambos se valoran de 1 a 5. Se calcula:

$$\boxed{R = P \times I}$$

Por ejemplo, si un ataque tiene probabilidad 4 e impacto 5, su riesgo es $4 \times 5 = 20$, clasificado como crítico.

Para cada activo seguimos cuatro pasos: identificar una amenaza y una vulnerabilidad; describir la consecuencia; asignar P e I con las escalas siguientes; y calcular el nivel de riesgo. Después seleccionamos un tratamiento y volvemos a valorar el mismo escenario para estimar su riesgo residual.

Tabla 3: Escala de probabilidad

P	Nivel	Criterio
1	Rara	Solo ocurriría en condiciones excepcionales o al superar una protección fuerte.
2	Poco probable	Existen protecciones y el ataque necesita una condición adicional difícil de conseguir.
3	Posible	Hay una forma viable de ataque, pero requiere acceso o condiciones particulares.
4	Probable	El intento es fácil de repetir y la debilidad permite aprovecharlo con poco esfuerzo.
5	Casi segura	La exposición es constante y prácticamente no existen barreras que impidan el evento.

Tabla 4: Escala de impacto

I	Nivel	Consecuencia considerada
1	Insignificante	Efecto mínimo, sin información privada expuesta ni interrupción relevante.
2	Menor	Error limitado a una operación y fácil de corregir.
3	Moderado	Afectación de un usuario, algunos mensajes o una función, sin comprometer todo el chat.
4	Grave	Exposición de una sala completa, afectación de varios usuarios o interrupción importante del servicio.
5	Crítico	Control de la administración, exposición de varias salas o afectación extensa de la base de datos y el servicio.

Para asignar el impacto consideramos el daño en confidencialidad, integridad y disponibilidad, y usamos el valor más alto que corresponda al escenario. Así evitamos sumar varias veces una misma consecuencia.

Tabla 5: Clasificación del riesgo

Resultado	Nivel	Interpretación
1–4	Bajo	Requiere mantener los controles y observar su funcionamiento.
5–9	Medio	Necesita medidas de protección y seguimiento.
10–16	Alto	Debe atenderse con prioridad por sus posibles consecuencias.
17–25	Crítico	Requiere atención inmediata dentro del diseño de seguridad.

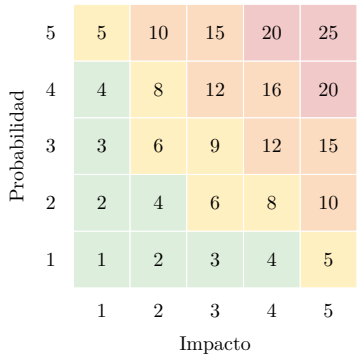


Figura 2: Matriz de probabilidad e impacto

3.2 Cálculo del riesgo residual

El riesgo residual se calcula con la misma fórmula, usando P e I después del tratamiento: $R_r = P_r \times I_r$. Las valoraciones de este trabajo son estimaciones de análisis: muestran la reducción que esperamos obtener con los controles planteados.

Un control puede reducir la probabilidad sin cambiar el impacto. Por ejemplo, una segunda verificación dificulta tomar la cuenta del administrador, pero, si el ataque tiene éxito, todavía permite actuar sobre todas las salas. El impacto solo disminuye cuando el control también limita el daño, como al separar la revisión de archivos del servidor del chat.

4 Políticas de seguridad

Consideramos las siguientes reglas para proteger las funciones principales de la aplicación. Se relacionan con el acceso, el uso de las salas y la protección de información. También recogen los enfoques del proyecto: verificar cada acceso, incorporar seguridad desde el diseño y revisar posibles fallos durante el desarrollo.

Tabla 6: Políticas de seguridad para la aplicación

Política	**Regla**
Acceso seguro	Usar contraseñas fuertes y una segunda verificación para el administrador. Proteger las claves de ingreso a las salas.
Control de sesiones	Permitir una sola conexión activa por usuario e invalidar la sesión al cerrarla.
Permisos	Solo el administrador puede crear, modificar o cerrar salas. Cada participante accede únicamente a las salas autorizadas.
Protección de comunicaciones	Cifrar el envío de mensajes y archivos, y proteger las claves utilizadas para ello.
Validación de información	Revisar los datos recibidos y evitar que los mensajes se ejecuten como código.
Archivos multimedia	Verificar archivos antes de compartirlos; rechazar los peligrosos y separar los sospechosos.
Esteganografía	Buscar indicios de información oculta y generar una alerta cuando el archivo sea sospechoso o el análisis no sea concluyente.
Disponibilidad	Limitar conexiones y envíos excesivos para evitar saturación del chat.
Registros y privacidad	Registrar accesos, cambios y eventos de seguridad sin guardar contraseñas ni contenido privado innecesario.
Desarrollo seguro	Revisar el código, mantener herramientas actualizadas y comprobar los controles de seguridad durante el desarrollo.

Estas políticas ayudan a convertir los riesgos en reglas de funcionamiento concretas. Los tratamientos de las fichas aplican esas reglas a cada caso.

5 Inventario de activos

Se identificaron quince activos relacionados con las funciones del chat. La columna CID señala las dimensiones afectadas por el riesgo que se analiza para cada uno.

Tabla 7: Quince activos y su importancia para el proyecto

ID	Activo	Importancia	CID
A01	Credenciales del administrador	Permiten administrar las salas.	C, I
A02	Claves de acceso a las salas	Restringen el ingreso a cada sala.	C
A03	Registro de sesiones activas	Permite controlar las conexiones de cada usuario.	I
A04	Identificadores de sesión	Permiten reconocer al usuario después de ingresar.	C, I
A05	Configuración y permisos de las salas	Define aforo, tipo de contenido y acciones permitidas.	I
A06	Canal de comunicación	Transporta mensajes y archivos entre usuario y servidor.	C, I
A07	Mensajes del chat	Conservan el contenido y la identidad del remitente.	I
A08	Interfaz de visualización del chat	Muestra los mensajes recibidos a los participantes.	C, I
A09	Claves de cifrado	Permiten proteger y recuperar la información cifrada.	C, I
A10	Base de datos de salas y usuarios	Guarda configuración y asociaciones de acceso.	C, I, D
A11	Archivos multimedia compartidos	Contienen la información enviada por los participantes.	C, I
A12	Herramienta de análisis de archivos	Revisa el contenido antes de permitir su distribución.	C, I, D
A13	Resultados del análisis de esteganografía	Ayudan a decidir si un archivo puede compartirse.	I, C
A14	Servidor del chat	Permite que los usuarios ingresen y se comuniquen.	D
A15	Registros de auditoría y alertas	Permiten conocer accesos, cambios y eventos de seguridad.	I, D

6 Evaluación general de riesgos

Cada riesgo corresponde al activo con el mismo número. La matriz permite comparar la valoración inicial con la residual; las fichas de la sección siguiente explican la amenaza, la vulnerabilidad, el tratamiento y la razón de cada cambio.

Tabla 8: Riesgo inherente y residual de los quince escenarios

ID	Escenario	P	I	Inicial	P_r	I_r	Residual
R01	Acceso a la administración	4	5	20 Crítico	2	5	10 Alto
R02	Ingreso ajeno a una sala	4	4	16 Alto	2	4	8 Medio
R03	Conexiones simultáneas	4	3	12 Alto	2	3	6 Medio
R04	Suplantación de sesión	3	4	12 Alto	2	4	8 Medio
R05	Cambios sin permiso	4	4	16 Alto	2	4	8 Medio
R06	Interceptación de mensajes	3	4	12 Alto	1	4	4 Bajo
R07	Remitente falso o duplicados	4	3	12 Alto	2	3	6 Medio
R08	Código malicioso en mensajes	4	4	16 Alto	2	4	8 Medio
R09	Robo de claves de cifrado	3	5	15 Alto	2	5	10 Alto
R10	Inyección SQL	3	5	15 Alto	1	5	5 Medio
R11	Archivo dañino compartido	4	4	16 Alto	2	4	8 Medio
R12	Fallo del analizador	3	5	15 Alto	2	3	6 Medio
R13	Contenido oculto no detectado	3	4	12 Alto	2	4	8 Medio
R14	Saturación del chat	4	4	16 Alto	3	3	9 Medio
R15	Borrado de registros	3	4	12 Alto	2	3	6 Medio

Ejemplo de lectura. R01 pasa de $4 \times 5 = 20$ (crítico) a $2 \times 5 = 10$ (alto). La segunda verificación reduce la probabilidad, pero el impacto sigue siendo 5 porque el administrador tiene acceso a todas las salas.

Resultado general. Inicialmente identificamos un riesgo crítico y catorce altos. Después de considerar los tratamientos, quedan dos altos, doce medios y uno bajo. R01 y R09 conservan mayor prioridad porque afectan la administración y las claves de cifrado. No todos los riesgos quedan bajos después de aplicar controles.

7 Análisis y tratamiento de los quince riesgos

7.1 R01 Credenciales del administrador

Tabla 9: Análisis del riesgo R01

Elemento	**Descripción**
Activo	A01: Credenciales del administrador. CID: C, I.
Amenaza	Un atacante intenta ingresar usando contraseñas robadas o adivinadas.
Vulnerabilidad	Contraseña débil y ausencia de una segunda verificación de identidad.
Riesgo	Acceso no autorizado a la administración y modificación o cierre de salas.
Evaluación inicial	P=4: Los intentos son fáciles de repetir en el acceso. I=5: La cuenta controla todas las salas. $R_i = 4 \times 5 = 20$ (Crítico).
Tratamiento	Usar contraseñas fuertes, limitar intentos y añadir una segunda verificación (MFA), como un código temporal. Guardar solo hashes de contraseñas: permiten verificarlas sin conservarlas en texto legible. [5].
Riesgo residual	$R_r = 2 \times 5 = 10$ (Alto). La segunda verificación reduce P a 2; I sigue en 5 porque el daño de tomar la cuenta continúa siendo amplio. Aún puede ocurrir engaño al administrador o robo de su dispositivo.

7.2 R02 Claves de acceso a las salas

Tabla 10: Análisis del riesgo R02

Elemento	**Descripción**
Activo	A02: Claves de acceso a las salas. CID: C.
Amenaza	Una persona ajena intenta adivinar la clave de una sala.
Vulnerabilidad	Claves cortas, previsibles o sin límite de intentos.
Riesgo	Ingreso de personas no invitadas y lectura del contenido de la sala.
Evaluación inicial	P=4: Una clave sencilla puede adivinarse mediante intentos repetidos. I=4: Se expone la conversación completa de una sala. $R_i = 4 \times 4 = 16$ (Alto).
Tratamiento	Generar claves difíciles de adivinar, limitar intentos y permitir cambiar la clave cuando se divulgue. Evitar almacenarla en texto legible. [5].
Riesgo residual	$R_r = 2 \times 4 = 8$ (Medio). P baja a 2; I permanece en 4. Un participante todavía puede compartir una clave válida con otra persona.

7.3 R03 Registro de sesiones activas

Tabla 11: Análisis del riesgo R03

Elemento	**Descripción**
Activo	A03: Registro de sesiones activas. CID: I.
Amenaza	Un usuario abre dos conexiones al mismo tiempo desde dispositivos diferentes.
Vulnerabilidad	No comprobar de forma conjunta si el usuario ya está conectado antes de admitir una nueva sesión.
Riesgo	Conexiones simultáneas que incumplen la restricción de un dispositivo por usuario.
Evaluación inicial	P=4: Abrir dos conexiones es sencillo si el control se realiza de forma incompleta. I=3: Afecta el control y la identificación de las acciones de un usuario. $R_i = 4 \times 3 = 12$ (Alto).
Tratamiento	Mantener un registro central de sesiones y rechazar una segunda conexión mientras exista la primera. Hacer la comprobación y el registro como una sola operación para evitar que dos ingresos se acepten a la vez. [4].
Riesgo residual	$R_r = 2 \times 3 = 6$ (Medio). P baja a 2; I se mantiene en 3. Pueden persistir fallos del registro o el uso de identidades distintas por una misma persona.

7.4 R04 Identificadores de sesión

Tabla 12: Análisis del riesgo R04

Elemento	**Descripción**
Activo	A04: Identificadores de sesión. CID: C, I.
Amenaza	Un atacante roba y reutiliza el identificador de una sesión válida.
Vulnerabilidad	Sesiones de larga duración o identificadores expuestos en enlaces y registros.
Riesgo	Suplantación de un usuario para leer o enviar contenido con sus permisos.
Evaluación inicial	P=3: El atacante debe obtener primero una sesión válida. I=4: Puede acceder a las salas de la identidad afectada. $R_i = 3 \times 4 = 12$ (Alto).
Tratamiento	Proteger el identificador de sesión, no incluirlo en enlaces ni registros y hacerlo vencer después de un tiempo de inactividad. Invalidarlo al cerrar sesión. [4].
Riesgo residual	$R_r = 2 \times 4 = 8$ (Medio). P baja a 2; I sigue en 4. Un dispositivo infectado aún puede permitir el uso indebido de una sesión activa.

7.5 R05 Configuración y permisos de las salas

Tabla 13: Análisis del riesgo R05

Elemento	**Descripción**
Activo	A05: Configuración y permisos de las salas. CID: I.
Amenaza	Un participante intenta cambiar o cerrar una sala sin ser administrador.
Vulnerabilidad	Comprobar permisos solo en la pantalla y no en el servidor.
Riesgo	Cambios no autorizados en el aforo, tipo de comunicación o estado de una sala.
Evaluación inicial	P=4: Un usuario puede enviar solicitudes aunque el botón no aparezca en su pantalla. I=4: Se altera el funcionamiento y la protección de la sala afectada. $R_i = 4 \times 4 = 16$ (Alto).
Tratamiento	Comprobar en el servidor quién puede crear, modificar y cerrar salas. Verificar también el aforo y el tipo de contenido permitido antes de aceptar cada acción. [4].
Riesgo residual	$R_r = 2 \times 4 = 8$ (Medio). P baja a 2; I continúa en 4. Un error de permisos en una nueva función todavía puede permitir cambios indebidos.

7.6 R06 Canal de comunicación

Tabla 14: Análisis del riesgo R06

Elemento	**Descripción**
Activo	A06: Canal de comunicación. CID: C, I.
Amenaza	Un tercero intercepta o modifica información durante su transmisión.
Vulnerabilidad	Comunicación sin cifrado o aceptación de certificados de seguridad inválidos.
Riesgo	Exposición o alteración de mensajes y datos de acceso mientras circulan por la red.
Evaluación inicial	P=3: El atacante necesita una posición que le permita interceptar la comunicación. I=4: Puede conocer el contenido de una conversación o sus datos de acceso. $R_i = 3 \times 4 = 12$ (Alto).
Tratamiento	Usar HTTPS y WSS, que protegen las comunicaciones mediante TLS, y certificados válidos. Impedir conexiones sin cifrado. [4].
Riesgo residual	$R_r = 1 \times 4 = 4$ (Bajo). P baja a 1; I permanece en 4. Un dispositivo comprometido puede revelar información antes de enviarla o después de recibirla.

7.7 R07 Mensajes del chat

Tabla 15: Análisis del riesgo R07

Elemento	Descripción
Activo	A07: Mensajes del chat. CID: I.
Amenaza	Un usuario envía mensajes usando la identidad de otro o repite envíos anteriores.
Vulnerabilidad	Aceptar como verdadero el remitente indicado por el usuario y no detectar mensajes duplicados.
Riesgo	Mensajes atribuidos a otra persona o repetidos que alteran la conversación.
Evaluación inicial	P=4: Un participante puede modificar los datos que envía o repetir una solicitud. I=3: Se afecta la integridad y confianza en los mensajes de la sala. $R_i = 4 \times 3 = 12$ (Alto).
Tratamiento	Obtener el remitente desde la sesión reconocida por el servidor, verificar que pertenece a la sala y comprobar identificadores de mensaje para evitar duplicados. [4].
Riesgo residual	$R_r = 2 \times 3 = 6$ (Medio). P baja a 2; I sigue en 3. Una cuenta robada puede seguir enviando mensajes que aparenten ser legítimos.

7.8 R08 Interfaz de visualización del chat

Tabla 16: Análisis del riesgo R08

Elemento	Descripción
Activo	A08: Interfaz de visualización del chat. CID: C, I.
Amenaza	Un usuario envía código malicioso dentro de un mensaje.
Vulnerabilidad	Mostrar el contenido recibido como código HTML ejecutable en lugar de texto.
Riesgo	Ejecución de acciones no deseadas en el navegador de otros participantes mediante XSS.
Evaluación inicial	P=4: El chat recibe y muestra contenido de usuarios, por lo que el intento es sencillo. I=4: Puede afectar a varios participantes que visualicen el mensaje. $R_i = 4 \times 4 = 16$ (Alto).
Tratamiento	Mostrar los mensajes como texto y evitar que se interpreten como instrucciones. Si se permite formato, eliminar etiquetas y atributos peligrosos antes de mostrarlos. XSS es la ejecución de código introducido en una página por un atacante. [6].
Riesgo residual	$R_r = 2 \times 4 = 8$ (Medio). P baja a 2; I se mantiene en 4. Una vista nueva que no aplique la protección puede volver a permitir el problema.

7.9 R09 Claves de cifrado

Tabla 17: Análisis del riesgo R09

Elemento	Descripción
Activo	A09: Claves de cifrado. CID: C, I.
Amenaza	Un tercero obtiene las claves utilizadas por la aplicación.
Vulnerabilidad	Guardar claves en el código o en archivos accesibles para personas no autorizadas.
Riesgo	Lectura de información cifrada o uso indebido de servicios que dependen de esas claves.
Evaluación inicial	P=3: El atacante necesita acceder al código, una configuración o una copia filtrada. I=5: Una clave compartida por el servicio puede afectar información de varias salas. $R_i = 3 \times 5 = 15$ (Alto).
Tratamiento	Guardar las claves fuera del código, restringir su acceso y cambiarlas si se sospecha una filtración. Separar las claves según su función para reducir el alcance del daño. [1].
Riesgo residual	$R_r = 2 \times 5 = 10$ (Alto). P baja a 2; I conserva el valor 5 mientras existan claves con acceso amplio. El programa necesita usarlas y un compromiso del servicio todavía puede exponerlas.

7.10 R10 Base de datos de salas y usuarios

Tabla 18: Análisis del riesgo R10

Elemento	Descripción
Activo	A10: Base de datos de salas y usuarios. CID: C, I, D.
Amenaza	Un atacante introduce datos que alteran una consulta a la base de datos.
Vulnerabilidad	Construir consultas uniendo directamente el texto enviado por el usuario.
Riesgo	Lectura o modificación no autorizada de información mediante inyección SQL.
Evaluación inicial	P=3: Depende de que existan consultas construidas de forma insegura. I=5: La base central contiene información de varias salas y usuarios. $R_i = 3 \times 5 = 15$ (Alto).
Tratamiento	Usar consultas parametrizadas: mantener separadas la instrucción de consulta y los datos del usuario. Limitar los permisos de la cuenta que utiliza la aplicación. [7].
Riesgo residual	$R_r = 1 \times 5 = 5$ (Medio). P baja a 1; I sigue en 5 porque el daño de acceder a la base completa continúa siendo alto. Una consulta nueva mal construida puede reintroducir el riesgo.

7.11 R11 Archivos multimedia compartidos

Tabla 19: Análisis del riesgo R11

Elemento	Descripción
Activo	A11: Archivos multimedia compartidos. CID: C, I.
Amenaza	Un usuario comparte un archivo malicioso disfrazado de imagen u otro contenido permitido.
Vulnerabilidad	Aceptar archivos solo por su nombre o extensión, sin revisar su contenido.
Riesgo	Distribución de archivos dañinos que afectan a quienes los descargan o abren.
Evaluación inicial	P=4: Un participante puede subir y renombrar archivos con facilidad. I=4: Puede comprometer a varios destinatarios dentro de una sala. $R_i = 4 \times 4 = 16$ (Alto).
Tratamiento	Comprobar el tipo real de archivo, limitar su tamaño y analizarlo antes de compartirlo. Rechazar archivos peligrosos y mantener los sospechosos en cuarentena, separados del contenido disponible. [8].
Riesgo residual	$R_r = 2 \times 4 = 8$ (Medio). P baja a 2; I se mantiene en 4. Algunos archivos maliciosos nuevos pueden superar el análisis.

7.12 R12 Herramienta de análisis de archivos

Tabla 20: Análisis del riesgo R12

Elemento	Descripción
Activo	A12: Herramienta de análisis de archivos. CID: C, I, D.
Amenaza	Un archivo preparado por un atacante provoca un fallo en la herramienta de análisis.
Vulnerabilidad	Procesar archivos con demasiados permisos y sin límites de recursos.
Riesgo	Interrupción del análisis o acceso indebido a otros componentes desde la herramienta afectada.
Evaluación inicial	P=3: Requiere un archivo que aproveche un fallo específico del analizador. I=5: Sin separación, el fallo puede afectar al servidor y a sus datos. $R_i = 3 \times 5 = 15$ (Alto).
Tratamiento	Ejecutar el análisis separado del chat, con permisos mínimos y límites de tiempo y memoria. Mantener actualizada la herramienta. [8].
Riesgo residual	$R_r = 2 \times 3 = 6$ (Medio). P baja a 2 e I a 3 porque la separación limita el daño al procesamiento de archivos. Puede persistir un fallo de la herramienta o de esa separación.

7.13 R13 Resultados del análisis de esteganografía

Tabla 21: Análisis del riesgo R13

Elemento	**Descripción**
Activo	A13: Resultados del análisis de esteganografía. CID: I, C.
Amenaza	Un usuario oculta información dentro de una imagen para evadir la revisión.
Vulnerabilidad	Utilizar un detector limitado y permitir archivos cuyo resultado no sea claro.
Riesgo	Circulación de contenido oculto que incumple la política de archivos del chat.
Evaluación inicial	P=3: Depende de la técnica de ocultamiento y de lo que pueda detectar la herramienta. I=4: Puede distribuirse información oculta entre los integrantes de una sala. $R_i = 3 \times 4 = 12$ (Alto).
Tratamiento	Aplicar esteganálisis, que busca indicios de información oculta; comparar su desempeño con archivos conocidos; retener archivos sospechosos o de resultado inconcluso y generar alertas. [9].
Riesgo residual	$R_r = 2 \times 4 = 8$ (Medio). P baja a 2; I permanece en 4. La detección puede fallar ante técnicas nuevas o alteraciones pequeñas; no asegura reconocer todos los casos.

7.14 R14 Servidor del chat

Tabla 22: Análisis del riesgo R14

Elemento	**Descripción**
Activo	A14: Servidor del chat. CID: D.
Amenaza	Un atacante envía demasiadas conexiones, mensajes o archivos.
Vulnerabilidad	No limitar solicitudes ni recursos utilizados por cada usuario.
Riesgo	Saturación del servicio que impide la comunicación de usuarios legítimos.
Evaluación inicial	P=4: Enviar solicitudes repetidas es fácil y puede automatizarse. I=4: La saturación puede interrumpir el chat para todos los participantes. $R_i = 4 \times 4 = 16$ (Alto).
Tratamiento	Limitar conexiones, frecuencia de mensajes y tamaños de archivos. Separar el procesamiento multimedia del chat y vigilar el uso de recursos. [4].
Riesgo residual	$R_r = 3 \times 3 = 9$ (Medio). P baja a 3 porque un ataque desde muchas fuentes aún es posible; I baja a 3 al contener la saturación y conservar recursos para el chat.

7.15 R15 Registros de auditoría y alertas

Tabla 23: Análisis del riesgo R15

Elemento	**Descripción**
Activo	A15: Registros de auditoría y alertas. CID: I, D.
Amenaza	Un intruso borra o modifica registros para ocultar sus acciones.
Vulnerabilidad	Guardar registros únicamente en el servidor del chat con permisos de modificación amplios.
Riesgo	Pérdida de información necesaria para identificar lo ocurrido y responder a un incidente.
Evaluación inicial	P=3: Requiere acceso al servidor o al almacenamiento de registros. I=4: La pérdida extensa de registros dificulta investigar eventos de todas las salas. $R_i = 3 \times 4 = 12$ (Alto).
Tratamiento	Guardar una copia de registros en un destino separado, restringir su modificación y registrar accesos, cambios de sala y archivos sospechosos. Evitar guardar contraseñas o contenido privado de mensajes. [1].
Riesgo residual	$R_r = 2 \times 3 = 6$ (Medio). P baja a 2 e I a 3 porque la copia separada conserva parte de la información. Pueden perderse eventos nuevos antes de registrarse.

8 Indicadores de seguridad

Se seleccionaron indicadores sencillos para observar si los controles cumplen su objetivo. La meta indica el resultado esperado; se medirá durante el desarrollo de la aplicación.

Tabla 24: Indicadores y metas de seguridad

Indicador	**Cómo se calcula**	**Meta**
Vulnerabilidades críticas abiertas	Número de vulnerabilidades graves identificadas que siguen sin corregirse.	0
Tiempo de corrección crítica	Horas desde identificar un fallo crítico hasta corregirlo.	Menos de 72 h
Administradores con segunda verificación	$100 \times A/B$, donde A es el número con MFA y B el total de administradores.	100%
Sesión única por usuario	$100 \times A/B$, donde A son los intentos de doble conexión correctamente bloqueados y B todos los intentos de doble conexión evaluados.	100%
Comunicación cifrada	$100 \times A/B$, donde A son las conexiones protegidas y B el total de conexiones evaluadas.	100%
Archivos revisados antes de compartir	$100 \times A/B$, donde A son los archivos compartidos después de su revisión y B el total de archivos compartidos.	100%
Casos conocidos de esteganografía detectados	$100 \times A/B$, donde A son los archivos de ejemplo con contenido oculto detectado y B todos los ejemplos alterados evaluados.	Al menos 95%
Eventos de seguridad registrados	$100 \times A/B$, donde A son los eventos registrados y B los eventos relevantes generados en la evaluación.	100%

La meta de detección de esteganografía se refiere a archivos de ejemplo cuyo contenido oculto ya conocemos; no significa que se pueda detectar cualquier técnica. Un resultado inconcluso no cuenta como detección correcta y el archivo permanece separado del contenido compartido. También conviene observar cuántos archivos normales son marcados como sospechosos para evitar bloqueos innecesarios.

Si un indicador no tiene casos evaluados, se registra como “sin datos” en lugar de asignarle un porcentaje de cumplimiento.

9 Conclusiones

El análisis permitió identificar quince activos y relacionar cada uno con una amenaza, una vulnerabilidad y una consecuencia. Consideramos que la administración, las claves de cifrado, el acceso a las salas y la revisión de archivos requieren especial atención por la información y funciones que protegen.

Los tratamientos reducen la exposición, pero no eliminan todos los riesgos. Por ello, el cálculo residual ayuda a reconocer qué problemas pueden permanecer y qué controles deben mantenerse. Las políticas y los indicadores ofrecen una base clara para continuar con el desarrollo seguro de la aplicación.

Referencias

[1] ISO/IEC. (2022). *ISO/IEC 27001:2022. Information security management systems – Requirements*. https://www.iso.org/standard/27001.

[2] ISO/IEC. (2011). *ISO/IEC 27034-1:2011. Application security – Part 1: Overview and concepts*. https://www.iso.org/standard/44378.html.

[3] ISO/IEC. (2022). *ISO/IEC 27005:2022. Guidance on managing information security risks*. https://www.iso.org/standard/80585.html.

[4] OWASP Foundation. (s. f.). *WebSocket Security Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/WebSocket_Security_Cheat_Sheet.html.

[5] OWASP Foundation. (s. f.). *Password Storage Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html.

[6] OWASP Foundation. (s. f.). *Cross Site Scripting Prevention Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html.

[7] OWASP Foundation. (s. f.). *SQL Injection Prevention Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html.

[8] OWASP Foundation. (s. f.). *File Upload Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html.

[9] Megías, D. y Lerch-Hostalot, D. (2022). *Subsequent embedding in targeted image steganalysis: Theoretical framework and practical applications*. https://doi.org/10.1109/TDSC.2022.3154967. Versión de autor: https://arxiv.org/abs/2107.13862.